

UNIVERSIDADE DE MOGI DAS CRUZES

BACHARELADO EM ENGENHARIA DE SOFTWARE

FELIPE AKROUCH FUJINAMI - RGM: 11231100326

**Desenvolvimento de uma Aplicação Web Segura para o
Studio de Pilates Samira Akrouch**

Mogi das Cruzes - SP

2026

1. Introdução

O presente projeto visa desenvolver uma aplicação web para o Studio Pilates Samira Akrouch, estruturada com um forte pilar em Segurança da Informação. O sistema atua como uma plataforma de gestão administrativa, oferecendo um ambiente autenticado e seguro para o controle operacional do negócio e armazenamento de dados sensíveis de saúde dos alunos. Através de um sistema de permissões hierárquicas (Role-Based Access Control - RBAC), a solução atende às necessidades específicas da CEO, secretários, professores e alunos, proporcionando uma experiência intuitiva e em conformidade rigorosa com a Lei Geral de Proteção de Dados (LGPD) e com as melhores práticas de cibersegurança e proteção de dados.

2. Objetivos

2.1. Objetivo Geral

Desenvolver uma aplicação web de gestão interna utilizando o framework Django e Python, permitindo o controle administrativo de alunos e o acesso altamente seguro às informações clínicas e contratuais.

2.2. Objetivos Específicos

- **Implementar níveis de acesso por perfil (RBAC):** Definir permissões distintas para CEO, Secretaria, Professor e Aluno.
- **Digitalizar a Ficha de Anamnese:** Disponibilizar o armazenamento seguro do histórico médico e físico dos alunos.
- **Aplicar medidas rigorosas de segurança:** Proteger o acesso através de Autenticação de Dois Fatores (2FA) baseada em TOTP.
- **Adequação à LGPD:** Implementar fluxos de consentimento explícito para o tratamento de dados pessoais e de saúde.
- **Recuperação Segura:** Fornecer um mecanismo de recuperação de senhas via códigos de uso único (OTP) enviados por e-mail.

3. Escopo

O projeto consiste no desenvolvimento do módulo de Gestão (Back-end e Front-end administrativo), acessível mediante autenticação, com funcionalidades específicas focadas nos seguintes perfis:

- **CEO e Secretaria:** Visão gerencial, cadastro completo de alunos (dados pessoais, endereço, anamnese médica, contrato), edição e exclusão de cadastros.
- **Professor:** Acesso à grade de aulas e visualização das restrições médicas dos alunos para garantir a segurança dos exercícios.
- **Alunos:** Acesso ao próprio painel para visualização do plano ativo, exigência de troca de senha no primeiro acesso e aceite formal dos termos da LGPD.

4. Levantamento de Requisitos

4.1. Requisitos Funcionais (RF)

Abaixo estão descritos os requisitos funcionais implementados na plataforma:

ID	Descrição	Prioridade
RF001	O sistema deve possuir autenticação baseada em e-mail e senha, com verificação de Dois Fatores (2FA) via app (TOTP).	Essencial
RF002	O sistema deve exigir a alteração da senha provisória no primeiro acesso do aluno.	Essencial
RF003	O sistema deve obrigar o usuário a ler e aceitar os Termos de Consentimento (LGPD) antes de acessar o dashboard.	Essencial
RF004	O sistema deve permitir à administração cadastrar, editar,	Essencial

ID	Descrição	Prioridade
	visualizar e excluir alunos (CRUD completo).	
RF005	O sistema deve registrar a ficha de Anamnese completa (doenças, cirurgias, dores, etc.) no cadastro do aluno.	Essencial
RF006	O sistema deve permitir a recuperação de senha via envio de código de 6 dígitos por e-mail, com expiração em 15 minutos.	Essencial
RF007	O sistema deve exibir um dashboard listando todos os alunos matriculados para usuários com perfil de gestão.	Essencial

4.2. Requisitos Não-Funcionais (RNF)

Abaixo estão descritos os requisitos não-funcionais com forte foco na área de Segurança da Informação e Arquitetura:

ID	Descrição	Prioridade
RNF001	As senhas devem ser armazenadas utilizando algoritmos de hash seguros providos nativamente pelo Django (PBKDF2).	Essencial
RNF002	O sistema deve gerar uma chave secreta TOTP (Base32) única para cada usuário para integração com Google Authenticator ou Authy.	Essencial

ID	Descrição	Prioridade
RNF003	O sistema deve impedir o acesso direto às rotas administrativas por usuários não autenticados, redirecionando-os para o login.	Essencial
RNF004	As views e formulários devem contar com proteção ativa contra ataques CSRF (Cross-Site Request Forgery).	Essencial
RNF005	A comunicação com o banco de dados deve utilizar exclusivamente o ORM do framework para mitigar riscos de SQL Injection.	Essencial
RNF006	As informações sensíveis da aplicação (Secret Key, credenciais de banco, credenciais de e-mail) devem ser geridas de forma segura por variáveis de ambiente (.env).	Essencial